Republic of Tunisia
Ministry of Higher Education and Scientific Research
Private Higher School of Technology and Engineering
TEK-UP

Academic Project Report for the Cyber Threat Intelligence

CYBER THREAT INTELLIGENCE REPORT

APT34: OilRig Hackers Group

Academic supervisor: Professor Oussama Riahi
Prepared by: Wejden Cherif & Maram Raboudi

Academic Year 2026/2027

Contents

List of Figures 6

Introduction 7

1 Executive Summary 8

1.1 Key intelligence findings . . . 8
1.2 Threat assessment . . . 8
1.3 Key takeaways for defenders . . . 8

CHAPTER I Profile of the Malicious Actor 9

2 Identity and Known Aliases . . . 9
2.1 Who calls it what . . . 9
3 Attribution Assessment . . . 10
3.1 Evidence supporting Iranian alignment . . . 10
3.2 Confidence model . . . 11
3.3 Alternative hypotheses . . . 12
4 Subgroups and Related Actors . . . 12
4.1 Lyceum (HEXANE / Storm-0133) . . . 12
4.2 BladedFeline . . . 12
4.3 Collaboration with other Iranian actors . . . 12
4.4 Confirmed versus assessed relationships . . . 12

CHAPTER II Main Objective and Motivation 14

5 Motivation and Strategic Objectives . . . 14
5.1 Strategic outcomes and operational enablers . . . 14
5.2 Four operational characteristics . . . 14
6 Geopolitical Context and Intelligence Requirements . . . 15
6.1 Regional context . . . 15
6.2 OilRig inside Iran's cyber ecosystem . . . 15
6.3 Likely intelligence requirements . . . 15
6.4 Evolution of objectives . . . 15
7 Targeting and Victimology . . . 16
7.1 Geography . . . 16
7.2 Sector by sector . . . 16
7.3 Target-selection patterns . . . 16

CHAPTER III Known Operations 18

8 Attack Lifecycle and Intrusion Analysis . . . 18
8.1 Impact assessment . . . 19
9 Initial Access and Social Engineering . . . 19
10 Credential Access and Identity Operations . . . 20
11 Infrastructure and Command-and-Control . . . 20
11.1 Traditional infrastructure . . . 21
11.2 Compromised infrastructure and web servers . . . 21
11.3 Exchange and cloud-based C2 . . . 21
11.4 Reuse, rotation and operational security . . . 21

CHAPTER IV Timeline of Activities **22**
12 Operational Timeline 2014–2026 . . . 22
12.1 Milestone table . . . 22
12.2 The four eras . . . 23
13 Evolution of APT34 Tradecraft . . . 24
13.1 Cloud adoption and emerging trends . . . 24

CHAPTER V Campaigns Conducted **25**
14 Campaign Cards . . . 25
14.1 Middle Eastern banking operations . . . 25
14.2 POWRUNER: BONDUPDATER . . . 25
14.3 DNSpionage: Karkoff . . . 25
14.4 HardPass . . . 25
14.5 Outer Space . . . 26
14.6 Juicy Mix . . . 26
14.7 Cloud-service-powered downloaders . . . 26
14.8 PowerExchange . . . 26
14.9 Israeli operations as a pattern . . . 27
14.10 Recent and related activity . . . 27
15 Cross-Campaign Comparison . . . 27

CHAPTER VI Toolkit of the Malicious Actor **29**
16 Malware and Tooling Ecosystem . . . 29
16.1 Toolkit at a glance . . . 29
16.2 Script era: Helminth, POWRUNER, BONDUPDATER, SideTwist . . . 30
16.3 .NET and DNS era: Karkoff, DNSpionage . . . 31
16.4 Compromised-site era: Solar and Mango . . . 31
16.5 Enterprise-service era: PowerExchange and cloud downloaders . . . 31
16.6 Malware evolution in one sentence . . . 31

17 Credential-Stealing Tools and Code Reuse . . . 31
17.1 Credential tooling . . . 31
17.2 Relationships between tools . . . 32
18 MITRE ATT&CK Mapping . . . 32
18.1 Technique highlights . . . 33

CHAPTER VII Detection, Risk and Defense **35**
19 CTI Analyst Analysis of APT34's Juicy Mix Campaign . . . 35
19.1 Campaign Overview . . . 35
19.2 Threat Actor and Strategic Intent . . . 35
19.3 Initial Access . . . 36
19.4 Execution and Persistence . . . 36
19.5 Command and Control . . . 37
19.6 Discovery and Remote Command Execution . . . 37
19.7 Credential and Browser Data Collection . . . 37
19.8 Post-Compromise Tooling . . . 38
19.9 Collection and Exfiltration . . . 38
19.10 Evolution from Outer Space to Juicy Mix . . . 38
19.11 MITRE ATT&CK Interpretation . . . 39
19.12 CTI Analyst Assessment . . . 39
19.13 Intelligence Value for Defenders . . . 40
20 Indicators of Compromise . . . 40
20.1 Documented indicators . . . 41
20.2 File names and other artifact types . . . 41
21 Detection and Hunting Opportunities . . . 42
21.1 Behavioral sequence . . . 43
21.2 Threat-hunting hypotheses . . . 43
22 Threat Intelligence Analysis and Correlation . . . 43
22.1 Three intelligence levels . . . 43
22.2 How campaigns are linked to OilRig . . . 44
22.3 Confidence scale used in this report . . . 44
22.4 Known unknowns and collection priorities . . . 44
23 Risk and Threat Assessment . . . 45
24 Defensive Recommendations . . . 45
25 Future Outlook . . . 46
25.1 Early-warning indicators of a new campaign . . . 46

Conclusion **47**

References and Intelligence Sources **48**

MITRE ATT&CK 48

Government sources 48

Security vendors 48

Source reliability 48

Appendix A: Acronyms and Terminology **49**

List of Figures

1 Simplified OilRig attack lifecycle 8
2 Naming landscape around G0049 9
3 Confidence levels for reported and assessed relationships 12
4 End-to-end OilRig attack chain 18
5 Evolution of OilRig command-and-control approaches 21
6 Selected milestones in the public history of APT34/OilRig 22
7 Analytical evolution of OilRig tooling 29
8 MITRE ATT&CK Enterprise Matrix, version 17 33
9 Representative ATT&CK techniques used by OilRig 33
10 Overview of components used in OilRig's Juicy Mix campaign 35
11 String obfuscation function used by Mango's VBS dropper 36
12 Overview of OilRig's Outer Space compromise chain 39

Introduction

Modern governments and critical sectors depend on digital systems, and that dependence has opened the door to Advanced Persistent Threats (APTs): patient, well-resourced operators that target specific organizations over long periods. Unlike opportunistic cybercrime, an APT is usually driven by strategic goals such as espionage, intelligence collection or political influence.

APT34, also known as **OilRig**, is a textbook case of state-aligned cyber activity. It has been publicly associated with Iranian interests and has targeted government bodies, banks, energy firms, telecom providers, chemical companies and healthcare organizations, mostly in the Middle East.

This report studies APT34/OilRig from a Cyber Threat Intelligence (CTI) point of view. Listing malware samples and Indicators of Compromise (IOCs) is not enough; the report therefore works at three levels:

- **Strategic:** who the actor is, what it wants, and whom it targets.
- **Operational:** its campaigns, infrastructure, malware and attack chains.
- **Tactical:** the techniques, ATT&CK mappings and indicators that defenders can turn into detections.

The analysis relies on public intelligence from MITRE ATT&CK, Mandiant / Google Cloud, ESET, Cisco Talos, Palo Alto Networks Unit 42 and CISA. Sources are cross-checked so that established facts are kept apart from assessments and hypotheses, and the report is explicit about the difficulty of attribution and about the different names vendors give to the same activity.

1 Executive Summary

1.1 Key intelligence findings

APT34 (OilRig) is a suspected Iranian threat group tracked by MITRE ATT&CK as **G0049**. Public reporting traces its activity back to at least 2014. Its victims are mostly in the **Middle East**, with recurring interest in **government, finance, energy, chemical** and **telecommunications** organizations.

The strongest assessment is that OilRig conducts **cyber-espionage in support of Iranian strategic interests**. Its campaigns combine spearphishing, exploitation of public vulnerabilities, PowerShell and script-based execution, credential theft, scheduled-task persistence, compromised infrastructure, DNS/HTTP communication and, more recently, abuse of **legitimate cloud services**.

The one thing to remember
OilRig changes its malware faster than it changes its mission . Tools, domains and C2 channels are replaced as soon as defenders catch up, while the goal stays the same: get in, stay in, steal credentials, collect information and exfiltrate it.

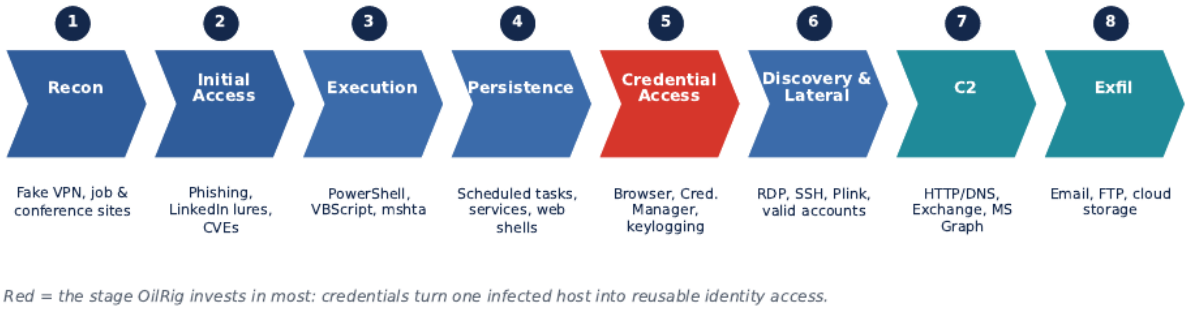


Figure 1: Simplified OilRig attack lifecycle, synthesized from public reporting and MITRE ATT&CK mappings. Red = the stage OilRig invests in most: credentials turn one infected host into reusable identity access.

1.2 Threat assessment

The threat is assessed as **sustained rather than campaign-specific**. The group has a long operational history, repeatedly targets strategically important sectors, keeps developing malware, and increasingly hides inside services that enterprises already trust: **Microsoft Exchange**, **Microsoft Graph** and **OneDrive**.

1.3 Key takeaways for defenders

- Monitor **behavior and context**, not static IOCs alone: infrastructure and hashes age quickly.
- Prioritize **phishing-resistant authentication**, PowerShell and script monitoring, and credential-theft detection.
- Watch for suspicious **scheduled-task and service creation** and anomalous Exchange / Microsoft Graph activity.
- **Correlate** endpoint, identity, DNS, email, network and cloud telemetry rather than running them as separate silos.

CHAPTER I Profile of the Malicious Actor

2 Identity and Known Aliases

One actor, many names: the same activity is labelled differently by almost every vendor.

MITRE ATT&CK tracks the group as **OilRig (G0049)** and associates it with the names COBALT GYPSY, IRN2, APT34, Helix Kitten, Evasive Serpens, Hazel Sandstorm, EUROPIUM, ITG13, Earth Simnavaz, Crambus and TA452. Each vendor sees different telemetry and clusters activity in its own way, so names may be merged, split or refined over time.

- **Attribute**: Primary name
  Assessment: OilRig
- **Attribute**: MITRE ATT&CK ID
  Assessment: G0049
- **Attribute**: Common alias
  Assessment: APT34 (merged with OilRig in MITRE)
- **Attribute**: Origin / alignment
  Assessment: Iran; Iranian government interests assessed
- **Attribute**: First publicly assessed activity
  Assessment: At least 2014
- **Attribute**: Primary mission
  Assessment: Cyber- espionage and intelligence collection
- **Attribute**: Primary region
  Assessment: Middle East, with international victims
- **Attribute**: Core sectors
  Assessment: Government, financial, energy, chemical, telecommunications

2.1 Who calls it what

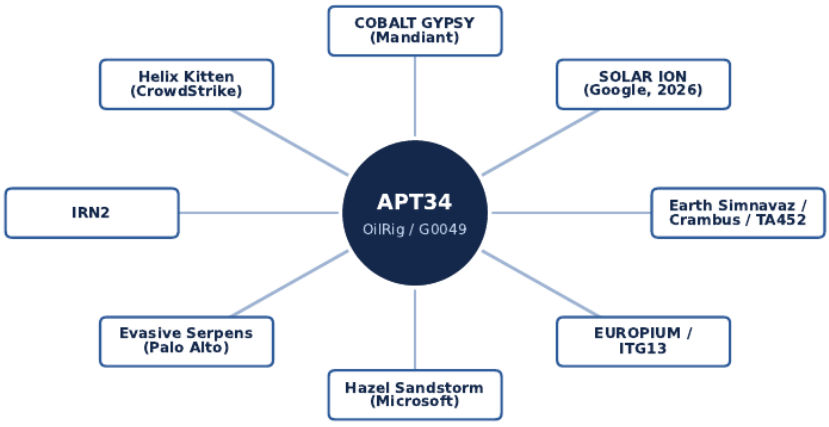


Figure 2: Naming landscape around G0049. Links show reported or assessed naming overlap, not automatic identity.

- **Name**: OilRig
  Used by: Palo Alto Networks Unit 42

How to treat it: Primary actor name; popularized the label

- **Name**: APT34
  Used by: Mandiant (Google Cloud)
  How to treat it: Previously tracked separately by MITRE, then combined
- **Name**: COBALT GYPSY, IRN2
  Used by: Secureworks
  How to treat it: Associated names in MITRE
- **Name**: HELIX KITTEN
  Used by: CrowdStrike
  How to treat it: Associated name in MITRE
- **Name**: Evasive Serpens
  Used by: Palo Alto Networks
  How to treat it: Vendor-specific name for G0049
- **Name**: Hazel Sandstorm, EUROPIUM
  Used by: Microsoft
  How to treat it: Current and former Microsoft names
- **Name**: ITG13
  Used by: IBM X-Force
  How to treat it: Associated name in MITRE
- **Name**: Earth Simnavaz
  Used by: Trend Micro
  How to treat it: Associated name in MITRE
- **Name**: Crambus, TA452
  Used by: Symantec, Proofpoint
  How to treat it: Associated names in MITRE
- **Name**: SOLAR ION
  Used by: Google Threat Intelligence
  How to treat it: 2026 naming system; a renaming, not a new actor

Analyst tip
An alias in a vendor report should not automatically be read as a separate actor . Map every name to the underlying evidence, and keep APT34/ OilRig as the working term, noting SOLAR ION as Google's current label.

3 Attribution Assessment

Iran alignment is well supported; exact organizational control is not public.

Attribution should be written as an evidence-based confidence judgment, never as a binary fact. For OilRig, several independent evidence streams point the same way, and that convergence is what makes the case strong.

3.1 Evidence supporting Iranian alignment

- **Evidence type**: Government assessment
  What the public record shows: Mandiant assessed in 2017 that APT34 operated on behalf of the Iranian government; MITRE repeats this and calls OilRig a suspected Iranian threat group.
- **Evidence type**: Infrastructure

What the public record shows: Historical infrastructure contained references to Iran and used Iranian infrastructure.

- **Evidence type**: Targeting
  What the public record shows: Government, energy, financial, chemical, telecom and Israeli strategic organizations fit an intelligence-collection profile.
- **Evidence type**: Technical tradecraft
  What the public record shows: A recurring mix of PowerShell, DNS/HTTP C2, credential theft, Office exploitation, scheduled tasks and custom downloaders appears across campaigns.
- **Evidence type**: Malware continuity
  What the public record shows: Tool succession such as Solar → Mango; ESET assigned SC5k, OilCheck, ODAgent and OilBooster to OilRig with HIGH confidence.
- **Evidence type**: Behavior
  What the public record shows: Repeated compromise of the same victims and migration from dedicated C2 to cloud services show a stable operational culture even as tools change.

3.2 Confidence model

- **Dimension**: Iran alignment
  Basis: Infrastructure references, targeting, consistent independent reporting
  Confidence: HIGH
- **Dimension**: Cyber-espionage mission
  Basis: Long-term reconnaissance and collection across strategic sectors
  Confidence: HIGH
- **Dimension**: Government sponsorship
  Basis: Mandiant and MITRE assessments; organizational details not public
  Confidence: HIGH (details not public)
- **Dimension**: APT34 ↔ OilRig overlap
  Basis: MITRE merged previously separate records
  Confidence: HIGH
- **Dimension**: Lyceum relationship
  Basis: ESET describes Lyceum/HEXANE/Storm-0133 as an OilRig subgroup
  Confidence: HIGH (ESET tracking)
- **Dimension**: BladedFeline relationship
  Basis: ESET: likely subgroup, based on tools, code similarity and targeting
  Confidence: MEDIUM
- **Dimension**: Exact operators / team
  Basis: Identities not established; not proven that every cluster is one team
  Confidence: LOW / unknown

Overall judgment

APT34/ OilRig is an Iran-aligned, state-sponsored or state-directed cyber-espionage actor, with HIGH confidence at the broad actor level. The evidence is much stronger for Iran alignment than for claims about internal structure or individual operators; subgroup claims must keep their own confidence labels. This prevents over-attribution while remaining useful to defenders.

3.3 Alternative hypotheses

Some overlaps could reflect **other Iranian groups, shared contractors, copied tools or common open-source components**. Lyceum and other Iranian clusters share parts of the regional targeting picture, so every cross-group relationship must be assessed on its own. Overall attribution to the OilRig/APT34 cluster is **HIGH**, but attribution of an individual campaign, subgroup or alias may be lower.

4 Subgroups and Related Actors

Related does not mean identical: the report keeps confirmed and assessed relationships apart.

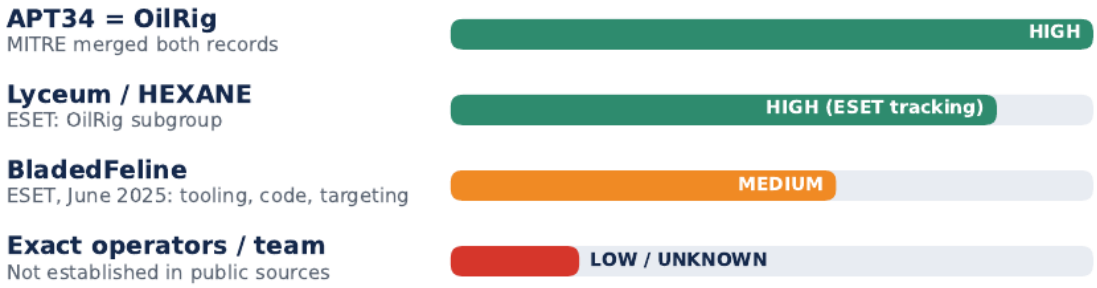


Figure 3: How strong is each relationship? Confidence bars follow the assessments cited in this section.

4.1 Lyceum (HEXANE / Storm-0133)

ESET describes Lyceum as an **OilRig subgroup** and links it to activity against Israeli government, local-government and healthcare organizations. Tools attributed to this subgroup include **DanBot, Shark, Milan, Marlin, Solar, Mango, OilForceGTX** and downloaders that use legitimate cloud services for C2. Other vendors track Lyceum separately, which illustrates the naming problem: the subgroup label keeps a link to the OilRig ecosystem *without* assuming one identical operational team.

4.2 BladedFeline

In research published on 5 June 2025, ESET assessed with **MEDIUM** confidence that **BladedFeline** is an OilRig subgroup. The assessment rests on three observations: shared Middle Eastern espionage targeting (including Iraqi and Kurdish officials), OilRig tools such as **RDAT** and **VideoSRV** on compromised systems, and code similarities between BladedFeline's **PrimeCache** IIS module and OilRig's RDAT backdoor. It is likely related, but **not an unquestionable synonym**.

4.3 Collaboration with other Iranian actors

ESET reported cooperation between **MuddyWater** and Lyceum in 2025. Overlap between Iran-aligned groups is better described as an *operational relationship* than as proof of a single organization.

4.4 Confirmed versus assessed relationships

- **Confirmed:** explicit, well-supported equivalence (for example APT34 = OilRig in MITRE).
- **Assessed:** evidence points to shared operators or tooling but does not prove organizational identity (for example BladedFeline).

- **Evidence**: Infrastructure
  Value for linking: Links campaigns through domains, IPs, services
  Strength: High if several pivots agree
  Main limitation: Rotates quickly
- **Evidence**: Malware / code
  Value for linking: Connects samples through implementation traits
  Strength: High if distinctive
  Main limitation: Code can be reused or copied
- **Evidence**: TTPs
  Value for linking: Shows recurring behavior
  Strength: Medium–High
  Main limitation: Many actors share techniques
- **Evidence**: Targeting
  Value for linking: Ties campaigns to strategic priorities
  Strength: Medium
  Main limitation: Several groups target the same sectors
- **Evidence**: Timing
  Value for linking: Supports operational continuity
  Strength: Medium
  Main limitation: Correlation is not causation
- **Evidence**: Aliases
  Value for linking: Normalizes vendor reporting
  Strength: High for explicit equivalence
  Main limitation: Taxonomies conflict

CHAPTER II Main Objective and Motivation

5 Motivation and Strategic Objectives

OilRig is an intelligence collector, not a criminal money-maker.

APT34/OilRig is best assessed as a strategic cyber-espionage actor rather than a financially motivated group. Public reporting consistently links its activity to the collection of information that supports Iranian geopolitical, economic and national-security interests. Mandiant's 2017 assessment described a long-term operation focused heavily on **reconnaissance**. The victim list (governments, banks, energy and oil-and-gas, chemical, telecom and, later, Israeli healthcare, manufacturing and local government) matches intelligence requirements, not opportunistic profit.

5.1 Strategic outcomes and operational enablers

- **Level**: Strategic outcome
  Objective: Intelligence on government decision-making, economic activity, energy and other strategic sectors
  What it looks like in practice: Mailboxes, documents, screenshots and system information collected from high-value victims
- **Level**: Strategic outcome
  Objective: Use of trusted relationships and supply-chain paths to reach higher-value targets
  What it looks like in practice: Compromised websites and professional/social lures
- **Level**: Operational enabler
  Objective: Credentials and reusable access
  What it looks like in practice: Browser theft, Credential Manager theft, keylogging, valid accounts
- **Level**: Operational enabler
  Objective: Long-term persistence
  What it looks like in practice: Malware, scheduled tasks, services, web shells, cloud accounts
- **Level**: Operational enabler
  Objective: Internal reconnaissance
  What it looks like in practice: Hosts, accounts, services, processes, network connections
- **Level**: Operational enabler
  Objective: Reliable C2 paths
  What it looks like in practice: HTTP/DNS, Exchange, Microsoft Graph, OneDrive

5.2 Four operational characteristics

- **Persistence and adaptability.** OilRig mixes conventional intrusion methods with custom tooling. It has used spearphishing and malicious documents, exploited newly disclosed vulnerabilities (Mandiant documented CVE-2017-0199 and CVE-2017-11882 in 2017) and relied heavily on PowerShell and other scripting.
- **Blending with trusted infrastructure.** Early operations used attacker-controlled HTTP/DNS servers and compromised websites; later activity moved into Microsoft Exchange, email and Microsoft Graph/OneDrive. Malicious traffic can therefore resemble ordinary enterprise communication, which weakens simple IP and domain blocking.
- **Credential-centric persistence.** Browser credential theft, Windows Credential Manager access, keylogging and valid accounts turn one infected endpoint into identity-based access that can survive malware removal.

- **Human-focused social engineering.** The 2019 HardPass campaign used LinkedIn and recruitment themes to build trust with targets in energy, government and oil and gas, bypassing defenses that only watch email.

6 Geopolitical Context and Intelligence Requirements

6.1 Regional context

OilRig operates in a region shaped by political tension, economic pressure and competition for influence. Its strongest focus remains the Middle East, where government and strategically important organizations hold information useful to Iranian interests. This explains the value of energy, finance and telecom targets. It supports the espionage assessment, but geopolitical relevance alone does not prove who directed a given intrusion.

6.2 OilRig inside Iran's cyber ecosystem

Iran's cyber operations involve several groups with different missions, capabilities and suspected institutional links. OilRig is one established espionage cluster, not a label for all Iranian activity. ESET has reported links between OilRig-related activity and other Iran-aligned groups such as Lyceum and MuddyWater; these remain assessed relationships. MITRE and Mandiant both assess that OilRig supports Iranian government interests: its role is to gain and keep access, steal credentials, move through networks and collect information.

6.3 Likely intelligence requirements

- **Requirement**: Government and diplomatic information
  Why OilRig's targeting suggests it: Policies, negotiations, officials and regional relationships
- **Requirement**: Economic intelligence
  Why OilRig's targeting suggests it: Financial institutions, commercial activity, economic relationships
- **Requirement**: Energy and industrial information
  Why OilRig's targeting suggests it: Oil and gas, chemicals, manufacturing and supply chains
- **Requirement**: Communications and identity data
  Why OilRig's targeting suggests it: Email, credentials, contacts and access to key personnel
- **Requirement**: Regional security information
  Why OilRig's targeting suggests it: Developments relevant to Iran's political and security interests
- **Requirement**: Persistent access
  Why OilRig's targeting suggests it: Credentials and trusted relationships that give continued access

6.4 Evolution of objectives

The main objective appears stable: collect intelligence that supports Iranian strategic interests. What changed is how. The group moved from malicious Office documents and PowerShell toward social-engineering lures, compromised infrastructure, Exchange-based C2 and legitimate cloud services, a clear effort to be harder to detect while keeping the same mission.

7 Targeting and Victimology

Targets are chosen for the information and access they offer.

7.1 Geography

OilRig has a strong Middle Eastern focus with selected international victims; MITRE describes activity against Middle Eastern and international organizations since at least 2014. Israel became a recurring focus from 2021, and reporting also names victims in Lebanon, the UAE and, via BladedFeline, Iraq and the Kurdish region.

7.2 Sector by sector

- **Sector**: Government
  Why it is valuable: Policy, diplomacy, regional security, decision makers
  Documented evidence: National and local government entities; BladedFeline against Iraqi and Kurdish officials (ESET, 2025)
- **Sector**: Energy, oil & gas
  Why it is valuable: Infrastructure, production, investment, supply chains, policy
  Documented evidence: Mandiant identified energy as one of APT34's strongest areas of interest
- **Sector**: Finance
  Why it is valuable: Economic and institutional intelligence
  Documented evidence: Middle Eastern banks attacked as early as 2016 with malicious Excel files
- **Sector**: Telecom
  Why it is valuable: Connects people, systems and other organizations; exposes communications data and access paths
  Documented evidence: Recurring in MITRE and Mandiant reporting
- **Sector**: Chemical
  Why it is valuable: Industrial knowledge, manufacturing capability, links to energy and economy
  Documented evidence: Appears repeatedly in OilRig reporting
- **Sector**: Healthcare
  Why it is valuable: Sensitive data; later expansion of the victim set
  Documented evidence: Israeli healthcare organization (ESET)
- **Sector**: Manufacturing
  Why it is valuable: Industrial and supply-chain value
  Documented evidence: Israeli manufacturing company (ESET)

7.3 Target-selection patterns

OilRig generally chooses organizations with strategic or information value: access to decision makers, sensitive data, credentials, communications and trusted relationships. A less prominent organization can also be chosen as a stepping stone (supply-chain access) toward a higher-value target. The victimology is consistent with an intelligence-led operation, not indiscriminate compromise.

Intelligence gap
The public record is incomplete. Vendors report only what they discover and investigate, so the absence of public reporting on a sector or country is an intelligence gap , not proof that

OilRig does not target it.

Overall targeting assessment
Targeting is strategic and information-driven, with a persistent Middle Eastern focus and recurring interest in government, finance, energy, chemical and telecom. Later reporting adds healthcare, manufacturing and local government. Access to people, credentials, communications and strategic organizations is itself a primary objective.

CHAPTER III Known Operations

8 Attack Lifecycle and Intrusion Analysis

Not every campaign uses every stage, but the pattern is remarkably consistent.

A typical intrusion can be read as one chain: **reconnaissance → phishing or exploitation → script-based execution → persistence → credential theft → discovery → lateral movement → collection → C2 over cloud, web, DNS or Exchange → exfiltration.**

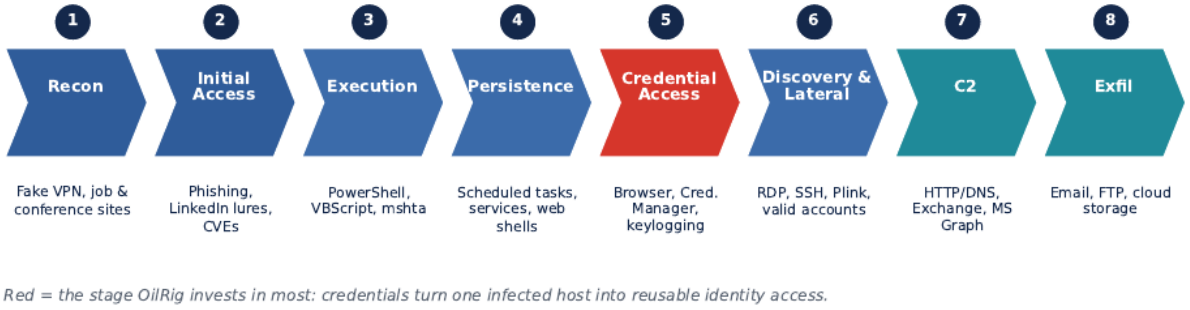


Figure 4: End-to-end OilRig attack chain; red marks the credential stage.

- **Stage**: Reconnaissance
  Observed OilRig behavior: Identifies accounts, domain groups, network connections, services, software and configuration; uses fake VPN portals, conference registrations and job sites to gather information
  MITRE ATT&CK: T1583.001, T1087, T1046, T1016, T1049, T1518
- **Stage**: Initial access
  Observed OilRig behavior: Malicious Office documents, malicious links, compromised email accounts, exploitation of public vulnerabilities; VPN, Citrix and OWA for access
  MITRE ATT&CK: T1566.001, T1204, T1203, T1133, T1586.002
- **Stage**: Execution
  Observed OilRig behavior: PowerShell, Windows Command Shell, VBScript, WMI and Office macros: flexible execution without one fixed malware family
  MITRE ATT&CK: T1059.001/.003/.005, T1047
- **Stage**: Persistence
  Observed OilRig behavior: Scheduled tasks, Windows services, registry mechanisms, Outlook Home Page abuse, remote-access accounts, web shells
  MITRE ATT&CK: T1053.005, T1543.003, T1137.004, T1505.003, T1133
- **Stage**: Privilege escalation
  Observed OilRig behavior: Credentials first, then local escalation; CVE-2024-30088 exploited for SYSTEM-level execution
  MITRE ATT&CK: T1068, T1078
- **Stage**: Defense evasion
  Observed OilRig behavior: Encoded or obfuscated files, masquerading, file deletion, legitimate cloud services, compromised sites; malware tested against security products
  MITRE ATT&CK: T1027, T1036, T1070.004, T1102, T1218.001
- **Stage**: Credential access
  Observed OilRig behavior: Browser stealers, Credential Manager theft, LaZagne , Mimikatz , keyloggers
  MITRE ATT&CK: T1555.003/.004, T1003, T1056.001, T1110

- **Stage**: Discovery
  Observed OilRig behavior: Users and groups, password policy, processes, services, network configuration, connections, installed software
  MITRE ATT&CK: T1087, T1069, T1201, T1057, T1007, T1016, T1049, T1033, T1518
- **Stage**: Lateral movement
  Observed OilRig behavior: Valid accounts, RDP, SSH/PuTTY, tunneling tools such as Plink or ngrok
  MITRE ATT&CK: T1078, T1021.001/.004, T1572, T1219
- **Stage**: Collection
  Observed OilRig behavior: Credentials, browser data, clipboard, screenshots, files, system information
  MITRE ATT&CK: T1119, T1115, T1113, T1217, T1555
- **Stage**: Command & control
  Observed OilRig behavior: HTTP and DNS first; later compromised servers, Exchange, Microsoft Graph, OneDrive; DNS as fallback
  MITRE ATT&CK: T1071.001/.004, T1102, T1572, T1008, T1573.002
- **Stage**: Exfiltration
  Observed OilRig behavior: Blended into existing channels: Exchange, FTP, cloud storage, sometimes separate from the main C2 path
  MITRE ATT&CK: T1048.003

8.1 Impact assessment

OilRig is an espionage actor, so destruction is not the normal end state. The main business risk is loss of **credentials, confidential information and strategic intelligence**, followed by persistent unauthorized access. In sensitive sectors that access can also reveal operations, relationships and future targets.

9 Initial Access and Social Engineering

Technical exploitation and human trust are combined; the lure is adapted to the victim's role and sector.

- **Method**: Spearphishing attachments
  How OilRig uses it: Office and RTF documents with macros, exploits or embedded content. The attachment is usually a delivery mechanism for scripts, exploits or a downloader, not the final payload.
- **Method**: Spearphishing links
  How OilRig uses it: Redirect victims to credential-harvesting pages or malware delivery infrastructure; useful to avoid attachment scanning.
- **Method**: Public vulnerabilities
  How OilRig uses it: Faster path to execution when vulnerable software is exposed (CVE-2017-0199, CVE-2017-11882, later CVE-2024-30088). Needs accurate victim and software intelligence.
- **Method**: Recruitment and professional lures
  How OilRig uses it: HardPass : attackers posed as recruiters on LinkedIn to establish trust before sending malicious content, making social context part of the attack surface.
- **Method**: Credential-based access
  How OilRig uses it: Stolen or purchased credentials give direct access to email, VPN,

remote desktop or cloud services, bypassing controls built only for malware delivery.

- **Method**: Trusted relationships
  How OilRig uses it: Interest in trusted websites, email infrastructure and professional relationships; even without a proven supply-chain compromise, abusing trusted infrastructure creates a similar detection challenge.

Evolution
The trend is from attachment-heavy intrusion to a mixed model : exploitation, credential use, social engineering and abuse of trusted services. The human layer remains important, while the technical layer has become more flexible.

10 Credential Access and Identity Operations

Malware can be removed; a stolen password, session or cloud identity keeps working.

Credentials are among OilRig's most valuable forms of access. The aim is rarely collection for its own sake: it is the **conversion of credentials into further access**.

- **Technique**: Credential harvesting
  Why it matters: Phishing pages, browser extraction, dumping tools and targeted collection turn endpoint access into reusable identities.
- **Technique**: Browser credential theft
  Why it matters: Tools extract saved passwords and authentication material; browsers are attractive because users reuse credentials across business services.
- **Technique**: Windows Credential Manager
  Why it matters: Stores credentials for remote services and applications; targeted during post-compromise collection (for example by VALUEVAULT).
- **Technique**: Keylogging
  Why it matters: Captures passwords that are not stored locally and reveals operational conversations and user behavior.
- **Technique**: Valid accounts
  Why it matters: The actor authenticates through normal enterprise pathways , reducing the malware needed and the noise produced.
- **Technique**: Credential reuse
  Why it matters: Allows movement between systems and access to higher-value accounts; password reuse is a strategic risk, not only a user-level weakness.
- **Technique**: Identity-based persistence
  Why it matters: Access tied to an account, token or remote-service credential survives malware removal, so monitoring authentication behavior is as important as endpoint cleanup.

11 Infrastructure and Command-and-Control

The important shift is not where the server sits, but how well the traffic imitates normal business activity.

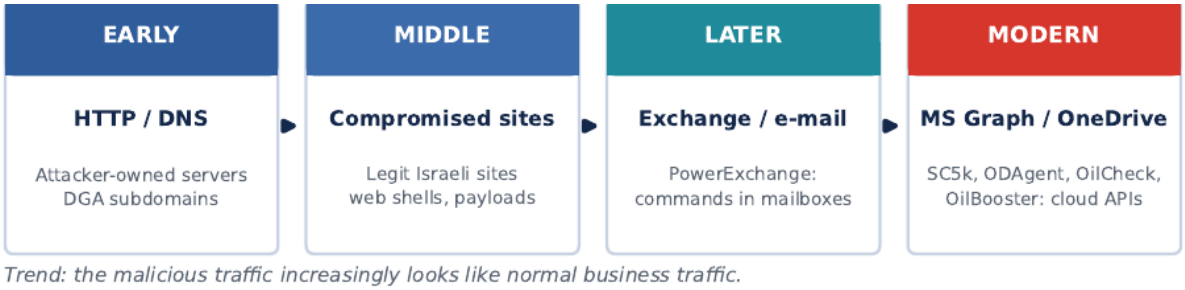


Figure 5: Evolution of OilRig command-and-control approaches, from attacker-owned servers to legitimate cloud APIs. Trend: the malicious traffic increasingly looks like normal business traffic.

11.1 Traditional infrastructure

Domains. Attacker-registered domains, dynamic subdomains and domains tied to malicious downloaders; rotation keeps access alive when infrastructure is exposed.

IP addresses. Dedicated C2 hosts and infrastructure connected to compromised services. IP indicators help retrospective hunting but age quickly.

DNS. DNS served both for discovery and as a covert or fallback channel. DNSpionage and related tools showed its value; BONDUPDATER used a domain-generation algorithm (DGA) so that fixed blocking becomes unreliable.

11.2 Compromised infrastructure and web servers

Compromised websites let OilRig's traffic appear to come from a legitimate organization. The Outer Space and Juicy Mix campaigns used compromised Israeli websites for C2, reducing dependence on obviously malicious servers. Web shells and compromised web servers provided both a foothold and a communication layer inside ordinary HTTP requests.

11.3 Exchange and cloud-based C2

- **Exchange C2:** PowerExchange used Microsoft Exchange email as the command channel; commands and results move through a system defenders expect to be active.
- **Cloud C2:** SC5k, ODAgent, OilCheck and OilBooster used Microsoft Graph, OneDrive, Outlook and Exchange Web Services for command retrieval, payload delivery and data transfer. The visible destination belongs to a trusted provider, which makes infrastructure attribution and blocking much harder.

11.4 Reuse, rotation and operational security

Infrastructure reuse often appears at the operational level (similar C2 patterns, hosting choices, malware behavior and victim targeting) rather than as one reused IP. OilRig can change domains, servers, compromised websites and cloud accounts while keeping the same workflow, which is why defenders should favor behavioral and identity-based detection.

CHAPTER IV Timeline of Activities

12 Operational Timeline 2014–2026

Four eras, one mission: strategic intelligence and durable access.

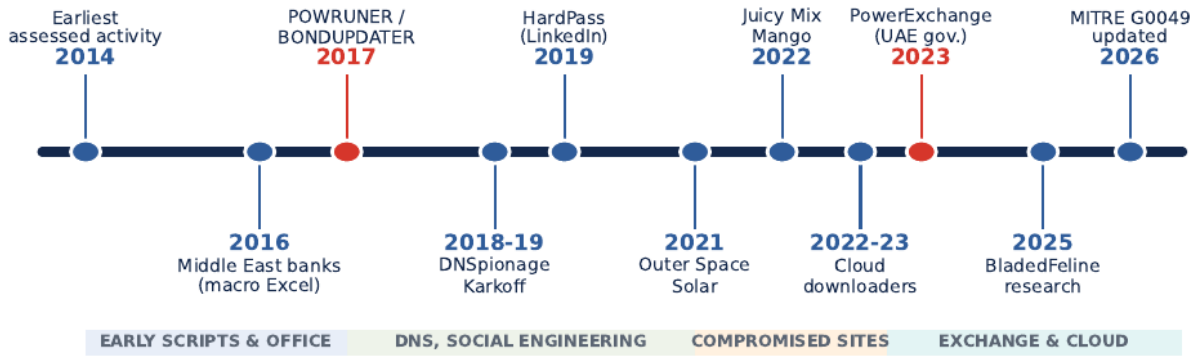


Figure 6: Selected milestones in the public history of APT34 / OilRig. Red markers are the 2017 exploit wave and the 2023 Exchange-based backdoor.

12.1 Milestone table

- **Period**: 2014
  Milestone: Earliest activity
  Intelligence significance: MITRE and Mandiant assess OilRig /APT34 activity from at least 2014
- **Period**: 2016
  Milestone: Middle Eastern banks
  Intelligence significance: Mandiant later attributed a macro-enabled Office spearphishing campaign to APT34
- **Period**: 2017
  Milestone: POWRUNER / BONDUPDATER
  Intelligence significance: Exploitation of CVE-2017-0199 and CVE-2017-11882; PowerShell and DGA-based C2
- **Period**: 2018–2019
  Milestone: DNSpionage / Karkoff
  Intelligence significance: DNS and HTTP communication; Karkoff documented by Cisco Talos in 2019
- **Period**: 2019
  Milestone: HardPass
  Intelligence significance: LinkedIn and recruitment-themed social engineering against strategic sectors
- **Period**: 2021
  Milestone: Outer Space
  Intelligence significance: Israeli targeting using Solar and compromised infrastructure
- **Period**: 2022
  Milestone: Juicy Mix
  Intelligence significance: Mango and renewed compromise of Israeli organizations
- **Period**: 2022–2023
  Milestone: Cloud-service C2

Intelligence significance: SC5k, ODAgent , OilCheck and OilBooster use Microsoft cloud APIs

- **Period**: 2023
  Milestone: PowerExchange
  Intelligence significance: Exchange/email-based C2 against a UAE government organization
- **Period**: 2024–2025
  Milestone: Evolving ecosystem
  Intelligence significance: Further exploitation; research into related and subgroup activity (BladedFeline)
- **Period**: 2026
  Milestone: Current picture
  Intelligence significance: MITRE G0049 updated; naming and subgroup relationships keep evolving

12.2 The four eras

Era 1: Emergence and scripts 2014–2017

WHAT HAPPENED: Activity assessed from at least 2014. By 2016 the group sent macro-enabled Excel attachments to Middle Eastern banks. In 2017 it expanded PowerShell use and quickly exploited newly disclosed Office vulnerabilities, using malicious documents and custom PowerShell backdoors (Mandiant, 7 December 2017).

SIGNATURE: Office documents + PowerShell + attacker-owned HTTP/DNS infrastructure.

Era 2: DNS and social engineering 2018–2019

WHAT HAPPENED: DNSpionage hit organizations in Lebanon and the UAE with malicious Office documents, fake job websites and HTTP/DNS C2. In 2019 Cisco Talos identified Karkoff, a lightweight .NET backdoor, and linked it to DNSpionage with high confidence through infrastructure overlaps. HardPass followed, using LinkedIn and recruitment themes (including impersonation of a Cambridge University contact).

SIGNATURE: DNS abuse, fake job lures, trust-based social engineering.

Era 3: Compromised sites and Israeli focus 2020–2022

WHAT HAPPENED: OilRig kept changing tooling and infrastructure instead of relying on one malware family, moving toward quieter access and compromised infrastructure. In 2021 Outer Space introduced the Solar backdoor and used a compromised Israeli website as C2; in 2022 Juicy Mix introduced Mango, a successor to Solar.

SIGNATURE: Compromised legitimate websites for C2; VBS droppers, PowerShell, scheduled tasks and credential stealers.

Era 4: Exchange and cloud services 2022–2026

WHAT HAPPENED: ESET documented SC5k, ODAgent , OilCheck and OilBooster abusing Microsoft Graph, OneDrive, Outlook and Exchange Web Services. In May 2023 ESET reported PowerExchange , a PowerShell backdoor using Exchange email, in a UAE government organization. MITRE updated G0049 in July 2026, and ESET's reporting also covers BladedFeline , Lyceum and exploitation of CVE-2024-30088.

SIGNATURE: Legitimate enterprise and cloud platforms as C2 and exfiltration channels.

Reading the timeline

Across 12 years the mission is stable and only the tradecraft moves: Office documents and scripts → compromised websites and credential theft → Exchange-based C2 → legitimate cloud services. The steady aim is to reduce detection while preserving the same collection workflow.

13 Evolution of APT34 Tradecraft

OilRig's evolution is less about becoming dramatically more sophisticated than about becoming harder to tell apart from normal enterprise activity.

- **Area**: Initial access
  Earlier: Spearphishing and malicious Office documents
  Later: Exploitation, recruitment lures, stolen credentials, abuse of trusted infrastructure
- **Area**: Malware
  Earlier: Script-heavy implants (Helminth, POWRUNER)
  Later: Purpose-built .NET backdoors (Solar, Mango), then lightweight cloud-service downloaders
- **Area**: Persistence
  Earlier: Scheduled tasks and registry mechanisms
  Later: Remote services, web shells, compromised websites and identity-based access
- **Area**: Credential theft
  Earlier: Traditional dumping and keylogging
  Later: Specialized theft of browser cookies/history, browser passwords and Credential Manager data
- **Area**: C2
  Earlier: Attacker-controlled HTTP/DNS
  Later: Compromised sites, Exchange, Microsoft Graph, OneDrive, EWS
- **Area**: Operational security
  Earlier: Infrastructure rotation
  Later: Obfuscated malware, compromised services, delivery chains adapted after public exposure

13.1 Cloud adoption and emerging trends

Cloud services became operational infrastructure for the actor, not merely victim resources. The clearest trend is deeper integration with identity and SaaS ecosystems: malicious automation operating through valid accounts, trusted APIs and ordinary enterprise services will stay hard to detect.

CHAPTER V Campaigns Conducted

14 Campaign Cards

Across campaigns the malware changes faster than the mission.

OilRig's campaigns show a steady shift from conventional spearphishing and custom scripts toward more selective social engineering, compromised infrastructure and legitimate cloud services. Each card below summarizes one campaign: when it happened, whom it hit, how access was gained, which tools were used, how C2 worked, and why it matters to an analyst.

14.1 Middle Eastern banking operations

Middle Eastern Banking Operations May 2016

TARGETS: Employees of Middle Eastern banks

INITIAL ACCESS: Macro-enabled Excel attachments sent by spearphishing

ACTIVITY: Reconnaissance, malicious documents, script execution and malware delivery; Mandiant later attributed the activity to APT34 (22 May 2016 report; attribution update 8 December 2017)

WHY IT MATTERS: Earliest well-documented OilRig operation; financial targeting fits intelligence collection, not necessarily financial gain

14.2 POWRUNER: BONDUPDATER

POWRUNER: BONDUPDATER 2017

INITIAL ACCESS: Exploitation of CVE-2017-0199 and CVE-2017-11882 via RTF documents

ATTACK CHAIN: RTF → mshta → PowerShell / VBScript → CertUtil → scheduled tasks

TOOLING: POWRUNER (PowerShell backdoor), BONDUPDATER (downloader with a custom DGA)

C2: DGA-based HTTP/DNS; infrastructure such as proxychecker [.]pro and mumbai -m[.]site

WHY IT MATTERS: Shows how quickly OilRig adopts newly disclosed vulnerabilities

14.3 DNSpionage: Karkoff

DNSpionage: Karkoff 2018–2019

TARGETS: Organizations in Lebanon and the UAE

INITIAL ACCESS: Malicious Office documents; fake job websites

TOOLING: A remote-administration tool using HTTP and DNS; by April 2019 Cisco Talos identified Karkoff, a lightweight .NET backdoor installable as a Windows service

WHY IT MATTERS: Demonstrates DNS as a covert channel; Talos observed changes in reconnaissance and infection procedures, and linked Karkoff to DNSpionage with high confidence

14.4 HardPass

HardPass 2019

TARGETS: Energy and utilities, government, oil and gas

INITIAL ACCESS: LinkedIn and recruitment-themed conversations (including impersonation of a Cambridge University contact) to build trust before delivering malicious files

TOOLING: New malware families and credential-stealing capabilities

WHY IT MATTERS: Social context became part of the attack surface; the approach bypasses defenses focused only on email

14.5 Outer Space

Outer Space 2021

TARGETS: Israeli organizations

TOOLING: Solar backdoor; post-compromise tools collecting browser and Windows credential data

C2: A legitimate Israeli human-resources website, compromised and reused as C2

WHY IT MATTERS: First clear example of the compromised-site C2 model; reported by ESET (21 September 2023)

14.6 Juicy Mix

Juicy Mix (MITRE C0044) 2022

TARGETS: Israeli organizations, again

TOOLING: Mango replaces Solar; VBS droppers, PowerShell, scheduled tasks, credential stealers

C2: Compromised Israeli infrastructure

WHY IT MATTERS: Incremental development: the Outer Space playbook reused with a new backdoor

14.7 Cloud-service-powered downloaders

Cloud-Service-Powered Downloaders 2022–2023

TARGETS: Israeli targets that OilRig had to keep access to

TOOLING: SC5k, ODAgent , OilCheck , OilBooster

C2 / EXFIL: Microsoft Graph, OneDrive, Outlook and Exchange Web Services

WHY IT MATTERS: Legitimate cloud services made traditional IP-based blocking much less useful; ESET published this research on 14 December 2023

14.8 PowerExchange

PowerExchange 2023

TARGETS: A UAE government organization (ESET, May 2023)

TOOLING: PowerExchange , a PowerShell backdoor

C2: Microsoft Exchange and email messages carry commands and stolen data

WHY IT MATTERS: C2 hidden inside normal enterprise messaging workflows

14.9 Israeli operations as a pattern

Recurring Israeli Operations 2021 onward

TARGETS: Government, healthcare, manufacturing, local government and other strategic entities

PATTERN: OilRig repeatedly returned to the same victims, deploying newer downloaders against previously compromised organizations

WHY IT MATTERS: Keeping access to specific victims mattered more than running isolated one-time campaigns

14.10 Recent and related activity

Recent Activity and Related Clusters 2024–2026

ACTIVITY: MITRE's current G0049 record includes exploitation of CVE-2024-30088; ESET reported BladedFeline in 2025 and assessed likely ties to OilRig

CAUTION: Treat these relationships as assessed, not as automatic identity

15 Cross-Campaign Comparison

- **Campaign**: Middle East banking (2016)
  Initial access: Spearphishing , Office macros
  C2: Dedicated infrastructure
  Intelligence value: Financial intelligence
- **Campaign**: POWRUNER / BONDUPDATER (2017)
  Initial access: Spearphishing , exploits
  C2: HTTP / DGA
  Intelligence value: PowerShell and resilient C2
- **Campaign**: DNSpionage / Karkoff (2018–19)
  Initial access: Spearphishing , fake job sites
  C2: DNS / HTTP
  Intelligence value: DNS abuse
- **Campaign**: HardPass (2019)
  Initial access: Professional networking
  C2: Malware infrastructure
  Intelligence value: Social engineering
- **Campaign**: Outer Space (2021)
  Initial access: Compromised sites
  C2: Web
  Intelligence value: Strategic Israeli targeting
- **Campaign**: Juicy Mix (2022)
  Initial access: Compromised sites
  C2: Web
  Intelligence value: Credential theft
- **Campaign**: Cloud downloaders (2022–23)
  Initial access: Trusted / compromised access
  C2: Graph, OneDrive
  Intelligence value: Cloud C2
- **Campaign**: PowerExchange (2023)

Initial access: Exchange / credentials
C2: Email / Exchange
Intelligence value: Enterprise email C2

Pattern across campaigns
Initial access moved from Office files toward professional-network lures and exploitation. C2 evolved from HTTP/DNS to compromised websites, Exchange and cloud APIs. Credential theft and repeat access to high-value victims stayed constant.

CHAPTER VI Toolkit of the Malicious Actor

16 Malware and Tooling Ecosystem

OilRig does not depend on one signature malware family; it keeps a changing collection of small, practical tools.

The common thread is **practical utility**: lightweight backdoors, downloaders, scripts and credential stealers that support access, discovery, credential theft and C2. OilRig develops small, task-focused tools and replaces them when defenders become familiar with a family. The progression from Helminth and POWRUNER to Solar, Mango, PowerExchange and the cloud downloaders shows growing specialization around the victim environment.

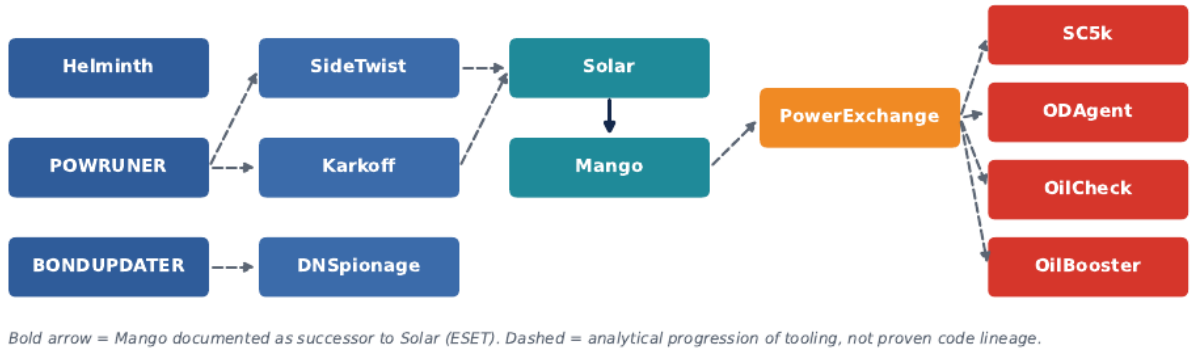


Figure 7: Analytical evolution of OilRig tooling. This is a progression of tool families, not a claim that each is a direct code successor of the previous one. Bold arrow = Mango documented as successor to Solar (ESET); dashed = analytical progression, not proven code lineage.

16.1 Toolkit at a glance

- **Tool / family**: Helminth
  Type: Backdoor / downloader
  Key capability: PowerShell, VBScript and batch execution; DNS and web C2; keylogging
  Seen in: Early campaigns
- **Tool / family**: POWRUNER
  Type: PowerShell backdoor
  Key capability: Command execution, host discovery, file transfer, screenshots
  Seen in: 2017
- **Tool / family**: BONDUPDATER
  Type: Downloader
  Key capability: Custom DGA for changing C2 subdomains
  Seen in: 2017
- **Tool / family**: SideTwist
  Type: Backdoor
  Key capability: Command execution, data transfer; small implant
  Seen in: Script-based chains
- **Tool / family**: Karkoff
  Type: .NET backdoor
  Key capability: Remote commands; installable as a Windows service
  Seen in: DNSpionage , 2019
- **Tool / family**: Solar

Type: Backdoor
Key capability: C2 and command execution via compromised sites
Seen in: Outer Space, 2021

- **Tool / family**: Mango
  Type: Backdoor
  Key capability: Solar successor; credential-theft support
  Seen in: Juicy Mix, 2022
- **Tool / family**: PowerExchange
  Type: PowerShell backdoor
  Key capability: Exchange email as C2 channel
  Seen in: 2023
- **Tool / family**: SC5k
  Type: Downloader
  Key capability: Microsoft 365 services for C2 / exfiltration
  Seen in: 2022–23
- **Tool / family**: ODAgent
  Type: Downloader
  Key capability: Microsoft Graph / OneDrive communication
  Seen in: 2022–23
- **Tool / family**: OilCheck
  Type: Downloader
  Key capability: Web-service C2, bidirectional transfer
  Seen in: 2022–23
- **Tool / family**: OilBooster
  Type: Downloader
  Key capability: Web protocols, local staging, encrypted comms, fallback channels, cloud exfiltration
  Seen in: 2022–23

16.2 Script era: Helminth, POWRUNER, BONDUPDATER, SideTwist

Helminth Backdoor / downloader

PROFILE: OilRig family tied to PowerShell, VBScript and batch execution.

CAPABILITIES: MITRE maps it to DNS and web C2, scheduled tasks, registry/startup persistence, keylogging, clipboard collection and local staging.

POWRUNER and BONDUPDATER 2017 pair

POWRUNER: PowerShell backdoor for command execution, host discovery, file transfer and screenshots. In 2017 it was launched through Task Scheduler and talked to C2 over HTTP/DNS.

BONDUPDATER: Downloader associated with POWRUNER. Its notable feature is a custom domain-generation algorithm that produces changing subdomains for C2 and payload retrieval.

SideTwist Backdoor

PROFILE: Lightweight backdoor for command execution and data transfer, reflecting OilRig's preference for small implants delivered through simple script-based chains.

16.3 .NET and DNS era: Karkoff, DNSpionage

Karkoff and DNSpionage 2018–2019

KARKOFF: Lightweight .NET backdoor found during DNSpionage activity; gave remote command execution and could be installed as a Windows service.

DNSPIONAGE: A campaign/toolset using HTTP and DNS communications, linked to OilRig . Its importance lies in the combination of remote administration, DNS-based communication and evolving infrastructure rather than in one executable.

16.4 Compromised-site era: Solar and Mango

Solar and Mango 2021–2022

SOLAR: Main backdoor of the 2021 Outer Space campaign; used with compromised Israeli infrastructure; supports command execution and C2.

MANGO: Replaced Solar in Juicy Mix (2022). Delivered through VBS and PowerShell chains; works with credential stealers, scheduled tasks and compromised infrastructure. ESET describes it as a successor to Solar with overlapping functionality.

16.5 Enterprise-service era: PowerExchange and cloud downloaders

PowerExchange 2023

PROFILE: PowerShell backdoor that uses Microsoft Exchange email for command and data exchange, moving C2 into a trusted enterprise channel.

SC5k, ODAgent , OilCheck , OilBooster Cloud-service downloaders

SC5K: Uses Microsoft 365 services for communication, so activity looks legitimate at network level.

ODAGENT: Abuses Microsoft cloud services; marks the move away from dedicated attacker-controlled C2.

OILCHECK: Mapped by MITRE to web-service communication and bidirectional transfer.

OILBOOSTER: Extends the approach with web protocols, local staging, encrypted communication, fallback channels and cloud-storage exfiltration: the most modular of the group.

16.6 Malware evolution in one sentence

The major change is not simply “new malware”; it is a change in **where the malicious logic lives**: from local scripts and dedicated servers toward cloud APIs, email and compromised legitimate infrastructure.

17 Credential-Stealing Tools and Code Reuse

17.1 Credential tooling

Credential theft is supported by both public and custom tools. MITRE documents LaZagne, PICKPOCKET, VALUEVAULT, browser stealers such as CDumper and EDumper, and other credential-focused utilities; Mimikatz and keyloggers also appear in operations.

- **Tool**: LaZagne , Mimikatz
  Target: Stored and in-memory credentials
  Role in the intrusion: Public credential dumping tools
- **Tool**: PICKPOCKET, CDumper , EDumper
  Target: Browser credentials and data
  Role in the intrusion: Custom browser stealers
- **Tool**: VALUEVAULT
  Target: Windows Credential Manager
  Role in the intrusion: Custom Credential Manager stealer
- **Tool**: KEYPUNCH
  Target: Keystrokes
  Role in the intrusion: Keylogging

These tools turn an endpoint compromise into reusable identity access.

17.2 Relationships between tools

The strongest relationships come from functional succession and shared tradecraft: Mango followed Solar, and the cloud downloaders share one operating model. Code and capability overlap can support attribution, but should be combined with infrastructure, targeting and timing, never treated as proof by itself, because common libraries and copied public code create false positives.

18 MITRE ATT&CK Mapping

OilRig swaps malware often but reuses familiar behaviors, which is why ATT&CK is such a good lens.

The current G0049 record maps activity across the whole intrusion lifecycle. The matrix below shows representative techniques per tactic; it is deliberately selective, not a full dump of MITRE's record.

The full enterprise matrix provides broader framework context; it is not an OilRig-specific mapping.



Figure 8: MITRE ATT&CK Enterprise Matrix, version 17.

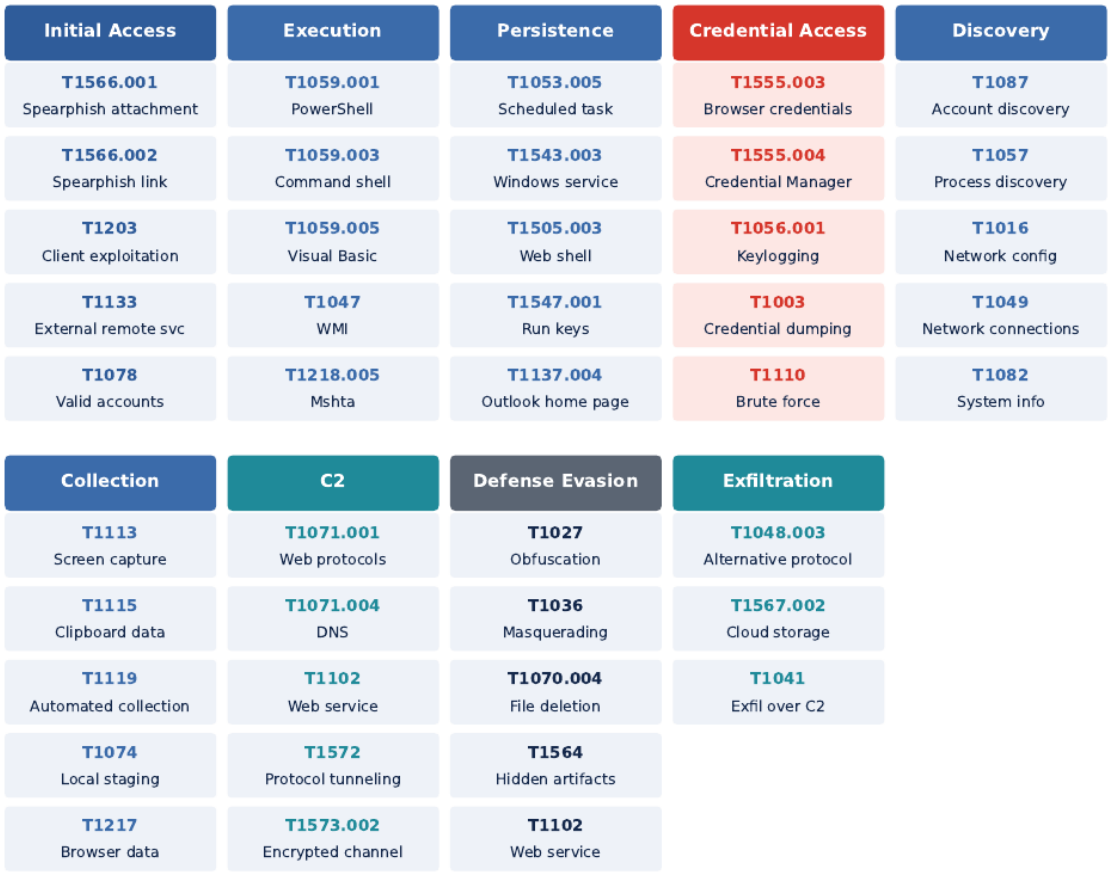


Figure 9: Representative ATT&CK techniques used by OilRig (credential access highlighted).

18.1 Technique highlights

- **Tactic**: Initial access
  Representative techniques: T1566.001, T1566.002, T1203, T1133, T1586.002, T1199
  Pattern: Phishing, client exploits, compromised accounts, external remote services
- **Tactic**: Execution
  Representative techniques: T1059.001, T1059.003, T1059.005, T1047, T1218.005
  Pattern: Scriptable execution without one fixed executable; mshta in older chains
- **Tactic**: Persistence
  Representative techniques: T1053.005, T1543.003, T1547.001, T1505.003, T1133
  Pattern: Choice depends on the victim environment
- **Tactic**: Credential access
  Representative techniques: T1555.003, T1555.004, T1003, T1056.001, T1110
  Pattern: One of the most consistent parts of the toolkit
- **Tactic**: Discovery
  Representative techniques: T1087, T1069, T1057, T1007, T1016, T1049, T1518
  Pattern: Quiet preparation before selecting the next host or account
- **Tactic**: Collection
  Representative techniques: T1119, T1217, T1115, T1113, T1074
  Pattern: Automated collection and local staging
- **Tactic**: C2

Representative techniques: T1071.001, T1071.004, T1102, T1572, T1573.002, T1008
Pattern: HTTP/DNS to compromised servers, Exchange and cloud APIs

- **Tactic**: Defense evasion
  Representative techniques: T1027, T1036, T1070.004, T1564, T1102
  Pattern: Obfuscation, masquerading, hidden windows, trusted services
- **Tactic**: Exfiltration
  Representative techniques: T1048.003, T1567.002, T1041
  Pattern: Alternative protocols (Exchange, FTP), cloud storage, web services

Coverage gap
ATT&CK gives strong visibility into endpoint and network behavior but not every operational detail. Gaps are most likely where activity hides inside legitimate services, compromised accounts, cloud APIs or encrypted traffic. Correlate identity, endpoint, DNS, proxy, Exchange and cloud telemetry rather than relying on malware hashes alone.

CHAPTER VII Detection, Risk and Defense

19 CTI Analyst Analysis of APT34's Juicy Mix Campaign

19.1 Campaign Overview

The Juicy Mix campaign was an APT34/OilRig cyberespionage operation conducted in 2022 against Israeli organizations. According to ESET Research, the campaign targeted Israeli organizations and involved the compromise of a legitimate Israeli job-portal website, which was subsequently used as command-and-control infrastructure. The operation deployed a new C#/.NET backdoor named Mango, together with several post-compromise tools designed primarily for credential and browser-data theft.

From a Cyber Threat Intelligence perspective, Juicy Mix is significant because it demonstrates a complete intrusion operation rather than an isolated malware deployment. The campaign combined initial access, execution, persistence, command and control, credential access, collection, and exfiltration into a coordinated attack chain.

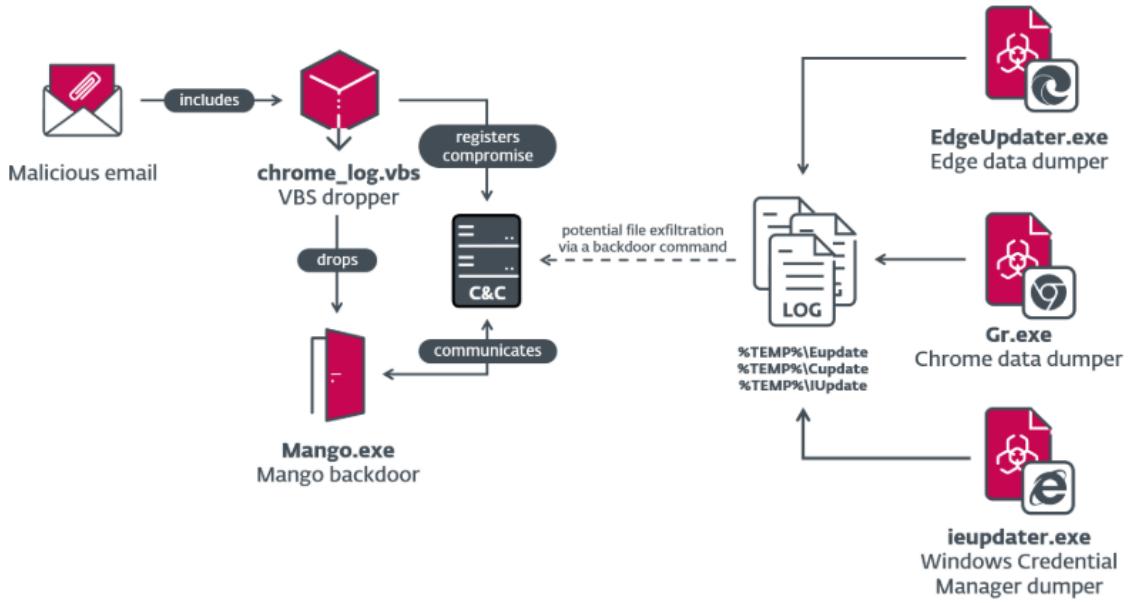


Figure 10: Overview of components used in OilRig's Juicy Mix campaign

19.2 Threat Actor and Strategic Intent

The activity was attributed to OilRig/APT34, an Iran-aligned cyberespionage group active since at least 2014. ESET associates the group with targeting Middle Eastern governments and organizations in sectors including chemical, energy, financial, and telecommunications.

The targeting observed in Juicy Mix is consistent with this strategic profile. ESET identified Israeli organizations as the exclusive targets of both the Outer Space campaign in 2021 and the Juicy Mix campaign in 2022.

The primary objective was intelligence collection, rather than destructive activity. The tools deployed during the campaign provided the operators with the ability to execute commands, gather information from compromised systems, steal browser data and credentials, and transfer selected files to attacker-controlled infrastructure.

19.3 Initial Access

The first stage of the operation involved VBS droppers, which ESET assesses were likely distributed through spearphishing emails.

The VBS dropper served several functions:

- Delivered the Mango backdoor to the victim system.
- Decoded the embedded payload.
- Created persistence through a scheduled task.
- Registered the compromised machine with the C2 infrastructure.

The dropper also used string obfuscation techniques to make its code more difficult to analyze and detect. The embedded Mango payload was stored as Base64-encoded data and reconstructed during execution.

```
Function Odo(idf)
idf = Replace(idf, Chr(35), Chr(48))
idf = Replace(idf, Chr(42), Chr(48))
idf = Replace(idf, Chr(43), Chr(48))
idf = Replace(idf, Chr(45), Chr(48))
idf = Replace(idf, Chr(95), Chr(48))
idf = Replace(idf, Chr(41), Chr(48))
idf = Replace(idf, Chr(40), Chr(48))
idf = Replace(idf, Chr(125), Chr(48))
idf = Replace(idf, Chr(123), Chr(48))
idf = Replace(idf, Chr(64), Chr(48))
idf = Replace(idf, Chr(36), Chr(48))
idf = Replace(idf, Chr(37), Chr(48))
idf = Replace(idf, Chr(94), Chr(48))
idf = Replace(idf, Chr(38), Chr(48))
Dim ghj5
For w = 1 To Len(idf) Step 3
    ghj5 = ghj5 & Chr(Mid(idf, w, 3))
Next
qwdl = StrReverse(ghj5)

Odo = qwdl

End Function
```

Figure 11: String obfuscation function used by Mango's VBS dropper

From a CTI perspective, this stage demonstrates the combination of social engineering, scripting, payload delivery, and obfuscation to establish the initial foothold.

19.4 Execution and Persistence

After the VBS dropper executed, it installed the Mango backdoor and established persistence through a scheduled task.

According to ESET's analysis, the scheduled task executed Mango repeatedly at approximately 32-second intervals, allowing the backdoor to maintain continuous communication with its C2 infrastructure.

This behavior is important for CTI analysts because scheduled-task creation shortly after suspicious script execution can provide a strong behavioral indicator of compromise.

The attacker therefore transformed the initial execution into a persistent foothold:

VBS execution → Mango deployment → Scheduled Task → Repeated execution

19.5 Command and Control

Once Mango was installed, it established communication with an attacker-controlled C2 server.

A particularly important characteristic of the campaign was the use of a legitimate Israeli job-portal website that had previously been compromised by OilRig. The website was abused as C2 infrastructure, allowing malicious communication to blend with legitimate web traffic.

Mango used encrypted communication and generated a victim identifier based on the machine name and username. Commands were exchanged through HTTP requests, with the data protected using XOR encryption and Base64 encoding, while TLS provided an additional layer of protection.

This represents an important CTI observation:

> APT34 did not rely exclusively on dedicated attacker-owned infrastructure; it also abused legitimate compromised infrastructure to make its communications less conspicuous.

19.6 Discovery and Remote Command Execution

The Mango backdoor provided operators with functionality for interacting with the compromised system.

Its commands included:

- Executing files and shell commands.
- Enumerating directories.
- Retrieving information from the victim system.
- Downloading files.
- Uploading selected files to the C2 server.

The ability to execute shell commands gave the operators flexibility after initial compromise. Instead of embedding every capability directly into the malware, the attackers could use the backdoor to perform additional operations when required.

For a CTI analyst, this means that the presence of Mango should not be analyzed independently. Its installation represented a platform for subsequent attacker activity.

19.7 Credential and Browser Data Collection

A major objective of the Juicy Mix operation was the theft of information stored by web browsers and Windows.

ESET identified previously undocumented browser-data stealers deployed alongside Mango. These tools targeted Chrome and Edge and collected:

- Browser cookies.
- Browsing history.
- Stored credentials.

ESET also identified a tool designed to steal information from Windows Credential Manager.

This capability significantly increased the value of the compromise. Browser credentials and authentication material could potentially provide access to additional services and accounts.

From a CTI perspective, the deployment of dedicated credential-stealing tools demonstrates that the operation was focused on expanding access and extracting valuable intelligence, rather than simply maintaining a single compromised endpoint.

19.8 Post-Compromise Tooling

APT34 did not depend exclusively on Mango.

ESET identified SampleCheck5000 (SC5k) among the post-compromise tools used by OilRig. SC5k used the Microsoft Office Exchange Web Services API for command and control. Operators could place commands and payloads inside draft email messages, which the downloader retrieved from the compromised Exchange account.

SC5k could:

- Retrieve commands from Exchange drafts.
- Download additional payloads.
- Execute commands using cmd.exe.
- Store command output.
- Transfer files from a local staging directory.
- Return results through Exchange draft messages.

This is particularly relevant from a CTI perspective because it demonstrates alternative C2 mechanisms and the abuse of legitimate enterprise services.

19.9 Collection and Exfiltration

After obtaining access and collecting credentials and browser information, the attackers could stage and transfer selected data.

Mango included functionality to upload selected files to the C2 server. SC5k also supported file exfiltration from local staging directories.

The overall collection process can therefore be represented as:

Identify valuable information → Collect → Stage locally → Transfer to C2

The campaign's focus on browser credentials, cookies, browsing history, system information, and selected files indicates an intelligence-collection objective.

19.10 Evolution from Outer Space to Juicy Mix

An important CTI finding is the relationship between the Outer Space campaign in 2021 and Juicy Mix in 2022.

ESET identified multiple similarities between the two campaigns:

- Both targeted Israeli organizations.
- Both compromised legitimate Israeli websites for C2.
- Both used VBS droppers.
- Both deployed C#/.NET backdoors.
- Both used similar post-compromise tooling.
- Mango was developed as a successor to Solar.

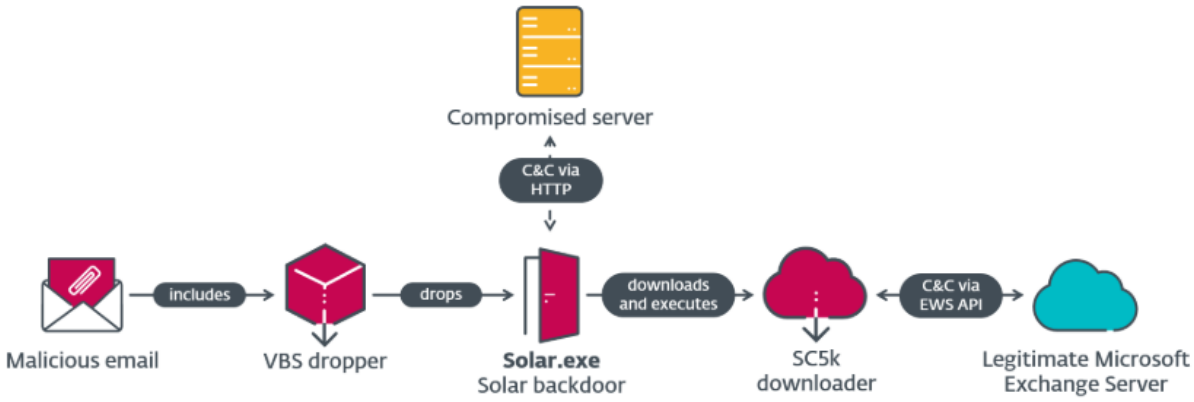


Figure 12: Overview of OilRig's Outer Space compromise chain

Mango retained similarities with Solar while introducing additional capabilities, including TLS-based C2 communication, native Windows APIs for executing files and commands, improved obfuscation, and additional exfiltration functionality.

This evolution is important intelligence because it demonstrates that APT34 learned from previous operations and modified its tooling rather than completely changing its operational methodology.

19.11 MITRE ATT&CK Interpretation

The Juicy Mix activity maps to the following MITRE ATT&CK techniques. Each row connects an observed behavior to its corresponding attack stage and technique identifier.

Attack stage	Observed behavior	ATT&CK technique
Initial access	Spearphishing or malicious VBS delivery	`T1566`
Execution	Visual Basic Script	`T1059.005`
Execution	Shell command execution	`T1059.003`
Persistence	Scheduled task	`T1053.005`
Command & Control	Application-layer communication over web protocols	`T1071.001`
Credential access	Browser credential theft	`T1555.003`
Credential access	Windows Credential Manager access	`T1555.004`
Collection	Local data staging	`T1074.001`
Exfiltration	Transfer of selected files	`T1041`

This mapping turns the campaign narrative into a structured view of adversary behavior.

19.12 CTI Analyst Assessment

From a CTI analyst perspective, the most important characteristic of Juicy Mix is the relationship between the individual activities.

A single PowerShell or script execution event may not indicate compromise. Similarly, a scheduled task or an external HTTPS connection may be legitimate.

However, the combination of:

> **Targeted delivery → VBS execution → Scheduled Task → Mango installation → C2 communication → Discovery → Credential theft → Data staging → Exfiltration**

creates a recognizable intrusion pattern.

This allows CTI teams to move beyond static indicators such as hashes, domains, and IP addresses and focus on behavioral intelligence.

The campaign also demonstrates APT34's ability to reuse successful operational concepts while improving its technical implementation. The transition from Solar to Mango illustrates this evolution clearly: the underlying operational model remained similar, while the backdoor gained additional capabilities and stronger obfuscation.

19.13 Intelligence Value for Defenders

The Juicy Mix campaign provides several actionable intelligence points for security operations:

- Monitor suspicious VBS and scripting activity, particularly when originating from email-delivered content.
- Detect newly created scheduled tasks associated with scripts or unusual executable locations.
- Monitor PowerShell and command-shell execution following suspicious initial access.
- Monitor access to browser credential stores and Windows Credential Manager.
- Inspect outbound connections to unusual or compromised legitimate websites.
- Monitor abnormal HTTP/HTTPS communication from endpoints.
- Correlate endpoint, email, identity, DNS, and network telemetry.
- Hunt for sequences of behaviors rather than isolated indicators.

The objective is to detect the intrusion before credential theft and data exfiltration are completed.

20 Indicators of Compromise

Treat IOCs as time-bound evidence, not permanent signatures.

Older domains and hashes identify historical campaigns, while behavioral indicators (PowerShell execution, DNS tunneling, Exchange-based C2, Microsoft Graph abuse) stay useful for newer variants. The examples below come from documented OilRig/APT34 reporting and are suitable for controlled threat hunting or retrospective analysis.

Handle with care
Domains and IPs are shown defanged ([.]). Validate every historical indicator against live telemetry before blocking: infrastructure can be recycled, sinkholed or reassigned.

20.1 Documented indicators

Indicator	Type	Confidence	Context
63D66D99E46FB93676A4F475A65566D8	MD5	HIGH	2017 APT34 malicious RTF
C9F16F0BE8C77F0170B9B6CE876ED7FB	MD5	HIGH	dupdatechecker.exe (2017)
1DE4810A10FA2D73CC589CA403A4390B02C6DA5E	SHA-1	HIGH	Solar.exe (ESET)
CB26EBDE498ECD2D7CBF1BC498E1BCBB2619A96C	SHA-1	HIGH	Mango.exe (ESET)
94.23.172[.]164	IPv4	HIGH	2017 APT34 host serving dupdatechecker.doc
199.102.48[.]42	IPv4	HIGH	ESET-reported host tecfor sc-001-site1.gtempurl[.]com; Outer Space / Juicy Mix
proxychecker[.]pro	Domain	HIGH	POWRUNER / BONDUPDATER C2
mumbai-m[.]site	Domain	HIGH	BONDUPDATER DGA infrastructure
rdppath[.]com	Domain	HIGH	QUADAGENT C2
dns-update[.]club, cpuproc[.]com, acrobatverify[.]com	Domain	HIGH	Historical OilRig reporting
hxxp://94.23.172[.]164/dupdatechecker.doc	URL	HIGH	2017 download URL
hxxp://mumbai-m[.]site/b.txt, hxxp://dns-update[.]club/v.txt	URL	HIGH	Proxy / web-log hunting
`HKCU\Office365DCOMCheck`	Registry	HIGH	QUADAGENT session ID and pre-shared key

20.2 File names and other artifact types

Treat these artifacts as leads for correlation, not standalone proof. Their value increases when they appear on the same host or account and align with the campaign timeline, suspicious execution, or network activity.

Endpoint and host artifacts

- **File names:** Reported examples include `dupatechecker.exe`, `hUpdateCheckers.ps1`, `Office365DCOMCheck.ps1` and its VBS variant, `SystemDiskClean.ps1` and its VBS variant, `AdobeAcrobatLicenseVerify.ps1`, and `Out.jpg` under the user's roaming application-data directory. Names alone are weak indicators because legitimate software may use similar strings; check path, signer, parent process, hash, and creation time.
- **Registry:** Correlate the QUADAGENT `HKCU\Office365DCOMCheck` key with associated scheduled-task creation and PowerShell or VBScript execution. Treat the key in isolation as insufficient evidence.
- **Mutexes and named pipes:** Public reporting does not establish a stable universal mutex or pipe. Preserve any campaign-specific value with its sample hash, source, and observation date; absence of a known value is not evidence that the host is clean.
- **Browser and Windows credentials:** Investigate suspicious access to Chrome or Edge profile data and Windows Credential Manager when it follows an unusual script, backdoor, or scheduled task.

Delivery, network, and cloud artifacts

- **Email:** Review recruitment-themed lures, malicious Office or RTF attachments, spoofed or compromised senders, mismatched reply-to addresses, and content tailored to the recipient's role. Mandiant also reported macro-enabled XLS attachments used against banks.
- **DNS:** Hunt for BONDUPDATER-like DGA subdomains, DNSpionage-style DNS command and control, and QUADAGENT fallback queries. High-entropy or rapidly changing subdomains from one endpoint are more useful when correlated with process, host, and timing data.
- **Cloud services:** Review unusual Microsoft Graph, OneDrive, Outlook, or Exchange Web Services activity from compromised endpoints; newly created attacker-controlled cloud accounts; unexpected OAuth grants; and API access by unfamiliar applications or service accounts.

Validity and handling: Hashes and exact URLs may have high source confidence but little current blocking value. Infrastructure indicators decay faster than behavioral patterns. Store each indicator with its source, confidence, campaign, and first-seen and last-seen dates; validate historical indicators against current telemetry before blocking.

21 Detection and Hunting Opportunities

Correlate endpoint, identity, email, DNS, proxy, and cloud telemetry. A single alert may be benign; prioritize combinations that follow the sequence of initial access, execution, persistence, credential access, command and control, and collection.

Endpoint execution and persistence

- Look for Office or RTF applications launching `mshta`, PowerShell, `wscript`, or `cscript`; scripts or executables written to user-writable directories; and scheduled tasks created shortly after suspicious execution.
- Enable PowerShell Script Block and Module Logging. Review encoded commands, download cradles, hidden windows, unusual parent processes, and scripts launched from user profiles or temporary locations.
- Investigate browser credential-store or Windows Credential Manager access when it follows suspicious scripting, backdoor execution, or task creation.

Network and DNS

- Review outbound connections to newly observed domains, direct-to-IP HTTP, unexpected PUT or POST transfers, and tunneling utilities such as Plink or `ngrok`.
- Hunt for high-entropy or unusually long DNS labels, frequent failed lookups, encoded host information in queries, and endpoints that switch to DNS after HTTP or HTTPS command-and-control failures.

Email and identity

- Review Office or RTF attachments, recruitment-themed messages, compromised internal senders, mismatched reply-to addresses, and messages followed by script-interpreter execution.
- Alert on impossible travel, unusual VPN, OWA, or Citrix access, first-time authentication from unfamiliar hosts, abnormal administrative logons, and repeated failures followed by success.

Microsoft 365 and Exchange

- Investigate Graph, OneDrive, Outlook, and EWS activity from unfamiliar applications; new

OAuth grants; anomalous token use; new or unusual service accounts; automated message creation or deletion; and machine-generated mail with unusual timing.

Correlate EDR, DNS, email, authentication, proxy, Windows event, PowerShell, Exchange audit, and Microsoft 365 audit logs. Escalate when multiple independent signals converge rather than on one static IOC alone.

21.1 Behavioral sequence

Build detections around *sequences*, which are more resilient than any single indicator:

Detection chain
phishing / exploit → script execution → scheduled task → credential access → discovery → cloud / Exchange comms

21.2 Threat-hunting hypotheses

- **H1.** A compromised host uses PowerShell to establish **periodic C2**.
- **H2.** An endpoint is querying **DGA-like domains**.
- **H3.** A user account authenticates from an unusual device after credential theft.
- **H4.** A cloud API is used for **automated bidirectional file transfer**.

22 Threat Intelligence Analysis and Correlation

22.1 Three intelligence levels

- **Strategic intelligence**
  - **Question:** Why is the actor operating, and whom does it target?
  - **Answer:** Public assessments describe an Iran-aligned espionage mission focused on strategic intelligence collection, especially from governments and strategically important industries in the Middle East.
  - **OilRig example:** Repeated interest in government, energy, finance, chemical, and telecommunications organizations.
- **Operational intelligence**
  - **Question:** How are campaigns conducted and sustained?
  - **Answer:** Campaigns combine targeted access, malware or legitimate-service command and control, persistence, credential theft, collection, and exfiltration; infrastructure and tools change across operations.
  - **OilRig example:** Outer Space and Juicy Mix shared Israeli targeting and compromised-site command and control; Mango followed Solar while extending its capabilities.
- **Tactical intelligence**
  - **Question:** What can defenders detect or act on now?
  - **Answer:** Hunt for documented indicators where relevant, and prioritize behaviors such as suspicious PowerShell, scheduled tasks, credential-store access, DNS patterns, and unusual Exchange or cloud API activity.
  - **OilRig example:** Correlate endpoint, identity, DNS, email, and Microsoft 365 telemetry instead of relying on a single hash or domain.

22.2 How campaigns are linked to OilRig

No single clue proves that two campaigns belong to OilRig. Stronger attribution combines several independent evidence categories.

- **Correlation method**: Domain and IP
  How it works and its limit: DNS history, certificates, hosting patterns, passive DNS, registration data; strongest when several features converge.
- **Correlation method**: Malware code
  How it works and its limit: Shared code, configuration formats, function names, encryption routines, development mistakes; beware common libraries and copied public code.
- **Correlation method**: Shared infrastructure
  How it works and its limit: Reused servers, compromised sites, cloud accounts or email infrastructure; confidence rises when reused together with the same malware or victim profile.
- **Correlation method**: Shared TTPs
  How it works and its limit: PowerShell, scheduled tasks, credential theft, DNS/HTTP C2 and cloud services form a behavioral fingerprint, more durable than IOCs.
- **Correlation method**: Targeting overlap
  How it works and its limit: Weak alone, because several Iranian groups pursue similar requirements.
- **Correlation method**: Timing
  How it works and its limit: New infrastructure soon after old infrastructure is exposed shows continuity; supports, never replaces, technical evidence.

22.3 Confidence scale used in this report

- **HIGH:** directly documented by a primary source or supported by multiple independent sources.
- **MEDIUM:** strong correlation or a single reliable source, with meaningful uncertainty.
- **LOW:** plausible assessment with limited direct evidence.
- **Unknown:** insufficient public evidence for a defensible assessment.

Confidence should attach to each claim, not only to the actor name.

22.4 Known unknowns and collection priorities

Intelligence gaps
Public reporting does not provide a complete current IOC set, a complete victim list, or visibility into OilRig's private cloud accounts and infrastructure. Exact relationships among vendor-named clusters and the extent to which older tools remain active are also unresolved. Some malware families are known only from limited samples.

Collection priorities: identity providers, Microsoft 365, Exchange, DNS, PowerShell, endpoint process trees, browser credential access and outbound network traffic. These sources cover OilRig's strongest observable behaviors.

23 Risk and Threat Assessment

Threat level: HIGH
For organizations in OilRig's historically targeted sectors and regions the threat is high. The risk comes from persistence, credential theft, trusted-service abuse and the ability to blend into normal enterprise operations.

- **Dimension**: Potential impact
  Assessment: Loss of sensitive information, credentials, strategic communications and intellectual property; compromised identities can create secondary access to partners and other systems.
- **Dimension**: Likelihood of targeting
  Assessment: Highest where the organization has strategic value to Iranian intelligence requirements, operates in a historically targeted sector, or exposes email, VPN, Exchange, identity or cloud infrastructure.
- **Dimension**: Most exposed sectors
  Assessment: Government, financial services, energy and oil/gas, chemical, telecommunications.
- **Dimension**: Attack surface
  Assessment: Public-facing applications, remote access services, email, identity providers, Microsoft 365, Exchange, browser credentials, endpoints.
- **Dimension**: Business risk
  Assessment: Confidential-data loss, regulatory exposure, account compromise, incident-response costs, compromise of trusted relationships.
- **Dimension**: Strategic risk
  Assessment: For governments and strategic industries, long-term national, economic and competitive consequences even without immediate destruction.

24 Defensive Recommendations

The strongest defense is layered detection: identity, endpoint, email, DNS/network and cloud data correlated, not run as isolated controls.

- **Layer**: Prevention
  Recommended actions: Patch public-facing systems quickly, remove unnecessary internet exposure, enforce least privilege, segment sensitive systems, restrict execution from user-writable directories.
- **Layer**: Identity protection
  Recommended actions: Phishing-resistant MFA, separate privileged accounts, conditional access, credential hygiene, session/token monitoring, rapid revocation after suspected compromise. CISA recommends phishing-resistant MFA, strong passwords, account auditing and least privilege against Iranian threat activity.
- **Layer**: Email security
  Recommended actions: Block or detonate suspicious Office/RTF attachments, inspect URLs, protect external forwarding, monitor compromised accounts, train users on recruitment and business-themed lures.
- **Layer**: Endpoint security
  Recommended actions: Monitor script interpreters, scheduled tasks, unusual child processes, browser credential-store access, credential dumping, suspicious files in AppData or temp locations.

- **Layer**: Network monitoring
  Recommended actions: Watch direct-to-IP connections, unusual DNS, HTTP POST traffic, tunneling tools, unexpected outbound connections from servers and admin systems.
- **Layer**: Cloud security
  Recommended actions: Detailed Microsoft 365 audit logging; monitor Graph, OneDrive, Exchange and OAuth; restrict application consent; investigate new accounts, tokens, service principals. CISA highlights authentication, token, logging and third-party risks in cloud identity infrastructure.
- **Layer**: Incident response
  Recommended actions: Isolate affected endpoints, revoke sessions and credentials, investigate identity providers and domain controllers, preserve cloud and endpoint logs, search for lateral movement before restoration.
- **Layer**: Threat hunting
  Recommended actions: Hypothesis-driven hunts on PowerShell, credential stores, scheduled tasks, DNS, Exchange automation, cloud API access, remote-service authentication.
- **Layer**: CTI integration
  Recommended actions: Normalize aliases, ingest time-scoped IOCs, map observations to ATT&CK, keep campaign-specific confidence scores; use behavior and relationships as the durable intelligence layer.

25 Future Outlook

The most likely direction is continued movement toward trusted infrastructure and identity-based access. OilRig's use of Exchange and cloud-service-powered tooling shows why future campaigns may lean on legitimate enterprise platforms instead of easily blocked dedicated servers.

- **Area**: TTPs
  Expectation: Continued blending of phishing, exploitation, valid accounts, scripting and cloud APIs; fewer obvious malware stages and more legitimate-looking administration.
- **Area**: Cloud and SaaS
  Expectation: Microsoft 365 and similar platforms stay attractive: authentication, storage, messaging and APIs without an obviously malicious destination.
- **Area**: Targeting
  Expectation: Strategic government and critical-industry organizations; suppliers and trusted partners as indirect paths to higher-value victims.
- **Area**: Malware
  Expectation: Modular, lightweight tools handing communication and storage to legitimate services.
- **Area**: Infrastructure
  Expectation: Dedicated servers coexisting with compromised sites, cloud accounts, email systems and APIs; blocking by IP or domain becomes insufficient.

25.1 Early-warning indicators of a new campaign

Watch for new Microsoft Graph/OneDrive applications, unusual Exchange automation, new cloud accounts linked to phishing, recurring victim organizations, new downloader families with similar configuration formats, and repeated use of the same identity or credential-theft workflow.

Conclusion

APT34/OilRig is a mature Iranian cyber-espionage capability whose strength comes from persistence and adaptation, not from reliance on a single malware family. Across campaigns it has combined social engineering, exploitation, scripting, credential theft, compromised infrastructure and legitimate enterprise services.

The clearest lesson for defenders is that OilRig cannot be stopped by IOC blocking alone. Organizations need visibility across identity, endpoint, email, DNS, network and cloud layers, with threat intelligence used to connect those observations into one intrusion story.

Top priorities

1. **Phishing-resistant identity protection and credential hygiene**
2. **Rapid patching of exposed systems**
3. **Strong endpoint telemetry (PowerShell, scheduled tasks, credential stores)**
4. **Microsoft 365 and Exchange monitoring**
5. **Continuous hunting for abnormal use of trusted services**

References and Intelligence Sources

MITRE ATT&CK

- OilRig (G0049), Version 5.0, last modified 31 July 2026
- Techniques: T1133, T1110, T1049, T1021.004, T1572, T1087.001, T1069.001, T1007, T1105
- SEASHARPEE (S0185), OilRig web shell

Government sources

- CISA, Securing Core Cloud Identity Infrastructure, 15 July 2025
- CISA/FBI, Iranian Government-Sponsored APT Actors Compromise Federal Network, Deploy Crypto Miner, Credential Harvester, 2022
- CISA/FBI/ACSC/NCSC, Iranian Government-Sponsored APT Actors Exploiting Microsoft Exchange and Fortinet Vulnerabilities, 2021

Security vendors

- Mandiant / Google Cloud, Targeted Attacks against Banks in the Middle East, 22 May 2016 (attribution update 8 December 2017)
- Mandiant / Google Cloud, New Targeted Attack in the Middle East by APT34, 7 December 2017
- Mandiant / Google Cloud, Hard Pass: Declining APT34's Invite to Join Their Professional Network, 18 July 2019
- Google Cloud, Updated Cyber Threat Actor Naming System, 2026
- Palo Alto Networks Unit 42, OilRig / QUADAGENT research; Iranian-linked cyber operations threat brief
- ESET Research, OilRig's Outer Space and Juicy Mix, 21 September 2023
- ESET Research, Iran-linked OilRig attacks Israeli organizations with cloud service-powered downloaders, 14 December 2023
- ESET Research, Iran-aligned BladedFeline spies on Iraqi and Kurdish officials, 5 June 2025
- ESET, APT Activity Report, October 2025–March 2026, 28 May 2026

Source reliability

- **Tier**: Tier 1
  Sources: MITRE ATT&CK, government advisories
  Best used for: Documented techniques, attribution assessments, defensive guidance
- **Tier**: Tier 2
  Sources: Primary security-vendor research
  Best used for: Malware, infrastructure, campaign and victim evidence
- **Tier**: Tier 3
  Sources: Reputable secondary and open-source reporting
  Best used for: Chronology and context; corroboration preferred

IOC confidence is HIGH when reported directly by a primary source, MEDIUM when independently correlated, and LOW when based mainly on uncorroborated reporting. Core technical and attribution claims prioritize MITRE, government and primary vendor research.

Appendix A: Acronyms and Terminology

- **APT**
  Meaning: Advanced Persistent Threat
- **EWS**
  Meaning: Exchange Web Services
- **C2**
  Meaning: Command and Control
- **DGA**
  Meaning: Domain Generation Algorithm
- **CTI**
  Meaning: Cyber Threat Intelligence
- **OSINT**
  Meaning: Open-Source Intelligence
- **IOC**
  Meaning: Indicator of Compromise
- **MFA**
  Meaning: Multi-Factor Authentication
- **TTP**
  Meaning: Tactics, Techniques and Procedures
- **SaaS**
  Meaning: Software as a Service
- **M365**
  Meaning: Microsoft 365
- **EDR**
  Meaning: Endpoint Detection and Response